# 加雲聯網股份有限公司

# Dummy Project - Threat and Risk Assessment Report

版 別：1.0

制訂日期：2024 年 5 月 XX 日

修訂日期：2024 年 5 月 XX 日

制修部門：XXX

頁 數：X

| 核准 | 審查 | 制定 |
| --- | --- | --- |
| | | |

# 文件發行/修訂記錄

| 版次 | 發行日期 | 生效日期 | 制修內容摘要 |
|---|---|---|---|
| 1.0 | | | |
| | | | |
| | | | |
| | | | |
| | | | |
| | | | |
| | | | |

## CONTENTS

1.0 Introduction ..... 4
1.1 Purpose and Objectives ..... 4
1.2 Scope of application ..... 4
1.3 Glossary of Term and Definitions ..... 4
1.3.1 Definitions ..... 4
1.3.2 Abbreviations ..... 4
1.4 Applicable Documents ..... 5
1.4.1 Employer's Requirements ..... 5
1.4.2 Related Documents ..... 5
2.0 Security Context ..... 6
2.1 SuC Description ..... 6
2.2 The assets of the SuC (updated by ILRA) ..... 7
2.3 Preliminary network architecture ..... 7
2.4 Data Flow Diagram (DFD) ..... 9
2.5 Possible Threats ..... 11
2.5.1 Description of the Threat Source ..... 11
2.5.2 Possible Threat Events ..... 14
2.6 Potential Impact to the Environment ..... 15
2.6.1 The possible sequence of attacks and impacts ..... 15
2.6.2 Unmitigated risks, security measures, and residual risks ..... 19
3.0 Security Profile ..... 20
3.1 The Proforma Form for Conducting the High-Level Cybersecurity Risk Assessment (HLCRA) results ..... 20
3.2 The Proforma Form for Conducting the Detailed Risk Assessment Requirements (DRAR) ..... 20
3.3 Analysis Tools and Results ..... 20
4.0 Requirements for Security Controls ..... 21
4.1 Cybersecurity Function Requirements Specification (Equipment/ Device Security) ..... 21
4.2 Data Protection Countermeasures ..... 21
4.3 Hardware Protection Countermeasures ..... 22
4.4 System Administration Countermeasures ..... 22
4.5 Application Security Countermeasures ..... 23
4.6 Network Security Countermeasures ..... 24
4.7 Advanced Mitigation Strategies ..... 24
4.8 Policies & Procedures Integration Requirements ..... 25

# 1.0 Introduction

## 1.1 Purpose and Objectives

The purpose of this document is to document the results and countermeasure requirements after ILRA and DTRA. This document describes the Security Context, Security Profile, Risk Assessment, and Requirements for Security Controls of the dummy project.

## 1.2 Scope of application

The System under Consideration (SuC) includes the power switch control system and Networks of the substation, the applicable scope of systems for this management plan includes:

1. Power switch control system:
   - SCADA system
   - Safety Control system
   - Configuration & Auxiliary management system

## 1.3 Glossary of Term and Definitions

### 1.3.1 Definitions

| **Definition** | **Description** |
|---|---|
| Asset Owner | Individual or organization responsible for one or more Industrial Automation and Control Systems (IACSs). |
| Automation Solution | Control system and any complementary hardware and software components installed and configured to operate in an IACS. |
| Component | One of the parts that make up a product or system. |
| Dependent Component | Component external to the product on which the product depends. |
| Integration Service Provider | Service provider that provides integration activities for an Automation Solution including design, installation, configuration, testing, commissioning, and handover. |
| Maintenance Service Provider | Service provider that provides support activities for an Automation Solution after handover. |
| Product Supplier | Manufacturer of hardware and/or software products. |
| Recovery Point Objective | Time value that determines the maximum tolerable period of data loss due to a disaster (e.g., data corruption). |
| Recovery Time Objective | The overall length of time an information system's components or an operation system's components can be in the recovery phase before negatively impacting the organization's mission or mission/business/operating functions. |
| Service Provider | Individual or organization (internal or external organization, manufacturer, etc.) that provides a specific support service and associated supplies in accordance with an agreement with the asset owner. |

### 1.3.2 Abbreviations

| **Abbreviation** | **Clarification** |
|---|---|
| ILRA | Initial Level Risk Assessment |

| Abbreviation | Clarification |
|---|---|
| DTRA | Detail Risk Assessment |
| SAT | Site Acceptance Test |
| SCS | Substation Control System |
| SIT | Site Integration Test |

## 1.4 Applicable Documents

### 1.4.1 Employer's Requirements

| No | Employer's DOC No | DOC Title | Ver |
|---|---|---|---|
| 1 | | | |
| 2 | | | |
| 3 | | | |

### 1.4.2 Related Documents

| No | Project's DOC No | Employer's DOC No | DOC Title | Ver |
|---|---|---|---|---|
| 1 | DUMMY202400## | BOSS202400## | Dummy - Preliminary network diagram | 1 |
| 2 | DUMMY202400## | BOSS202400## | Dummy – Data flow diagram | 1 |
| 3 | DUMMY202400## | BOSS202400## | Dummy Project - Inventory Asset List | 1 |
| 4 | DUMMY202400## | BOSS202400## | Dummy Project - ILRA-DTRA | 1 |
| 5 | | | | |

# 2.0 Security Context

## 2.1 SuC Description

A substation is a complex system composed of many elements such as transformers, capacitors, voltage regulators, and circuit breakers. Automated substation control will be implemented extensively in the smart grid systems to provide real-time monitoring and control through local area networks. Figure 2-1 shows the system architecture diagram of a substation.

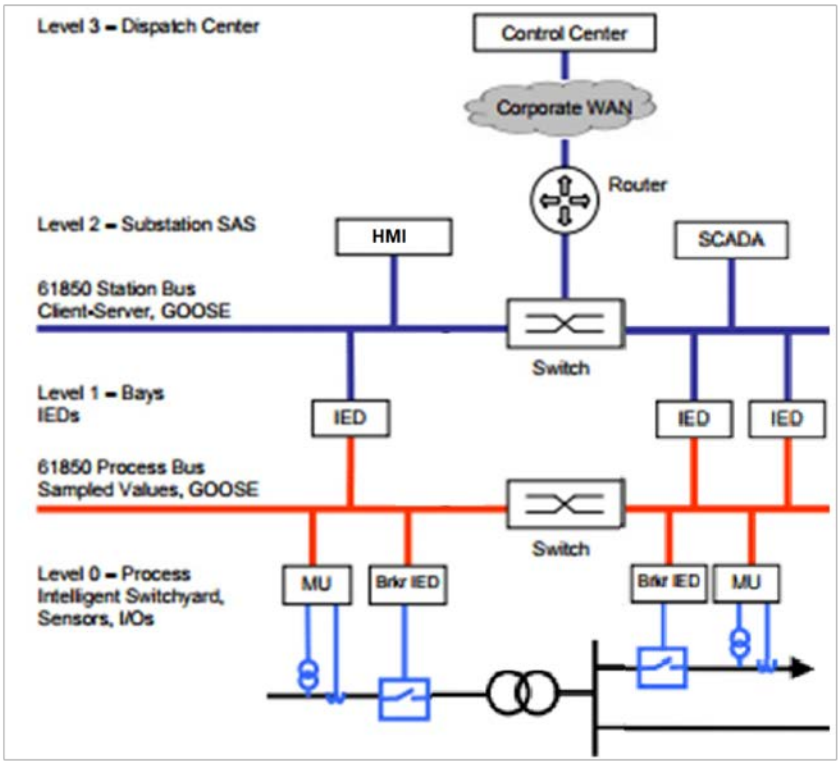



Figure 2-1 The system architecture diagram of the substation.

Substations are a critical component for maintaining electrical supply and load control in low voltage, medium voltage and high voltage electrical distribution networks. In order to ensure the proper functioning of substations and related equipment such as line-mounted switches and capacitors, most utilities use SCADA (supervisory control and data acquisition) systems to automate monitoring and control.

New sites typically implement a SCADA system to monitor and control substations and related equipment. However, older facilities can also benefit by adding a SCADA system or by upgrading an existing SCADA system to take advantage of newer technologies.

Not only will a new or upgraded SCADA system provide better monitoring and control, it can also extend the life of substations and related equipment by providing current data for troubleshooting small problems before they escalate. Furthermore, the ample historical data provided by SCADA systems can improve preventive maintenance scheduling and cut associated costs.

Electrical distribution systems involve many remote applications and sites, and monitoring and controlling these sites has often been difficult. To solve this problem, utilities began installing remote terminal/telemetry units (RTUs) at substations. Early RTUs were initially custom-made units, but later versions relied on standard hardware such as programmable logic controllers (PLCs) or industrial PCs. Intelligent electronic devices (IEDs) are a more recent technology development, and these devices are now installed at most substations to some extent. These IEDs generally communicate with the substation RTU.

Power distribution to various electrical loads at substations is controlled by switchgear feeders. Sensors mounted on the switchgear collect various data on current, voltage, power and switchgear status. This data is transferred to the RTU, which is in turn polled by a SCADA system.

The SCADA system consists of a master control station with one or more PC-based human machine interfaces (HMIs). The SCADA system may also contain other secondary control stations with HMIs, and large substations may also have local HMIs.

Operators view information on the HMIs to monitor and control substation operations and related equipment. Modern SCADA systems are extremely adept at handling the large amounts of data necessary to monitor the electrical state of all power lines, cables and equipment.

(Refer to “Dummy Project - Data Flow Diagram.doc” chap 2.1)

## 2.2 The assets of the SuC (updated by ILRA)

The initial assets of the system under consideration (SuC) corresponds to the scope of work in this project include :

1. SCADA system:
   (1) SCADA HMI
   (2) IED (Control)
   (3) Ethernet Switch
2. Safety Control system
   (1) IED (Protection)
   (2) Ethernet Switch
3. Configuration & Auxiliary management system
   (1) Wireless AP (could be connected to a laptop)

The Detail asset lists could refer to “Dummy Project - Inventory Asset List .xlsx” .

## 2.3 Preliminary network architecture

The ILRA updated Network Diagram of the SuC could refer to Figure 2-2 ILRA updated Network Diagram of the SuC. After ILRA analysis and partition the zones and conduits, the preliminary required equipments of security countermeasures also be presented in the diagram. For detail could refer to “Dummy - Update network diagram (ILRA).pdf”

(Refer to “Dummy Project - Data Flow Diagram.doc” chap 3.0)

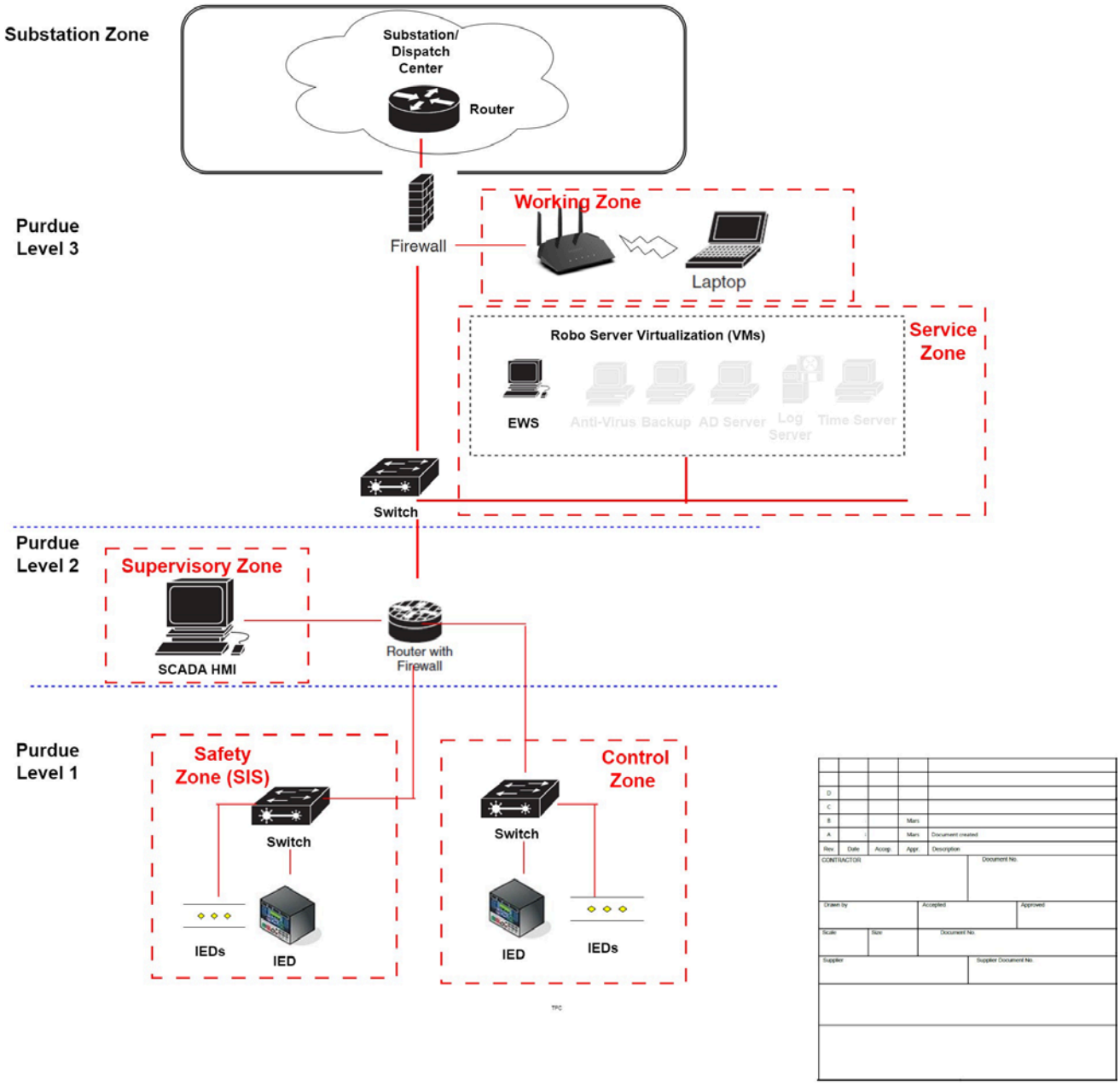



Figure 2-2 ILRA updated Network Diagram of the SuC.

## 2.4 Safeguarding Requirements of Data Storage Points/Document and Dataflows Identification

It shall identify and document data storage points and data flows within the SuC that require safeguarding, as defined, or approved by the PE/O or Security Policy and Procedures Plan, the types of the protected data includes:

- legal or regulatory information,
- PE/O confidential data, including proprietary data (e.g. recipes) and data identified in NDAs or other contractual vehicles, if applicable,
- configuration and operational data (e.g. commands and parameters),
- system data, including cryptographic materials (e.g. keys and certificates), access control lists, passwords, network device data, , if applicable,
- audit and event logs,
- backup data,
- historical data.

The security requirements for their safeguarding, such as confidentiality, integrity, availability. Access controls of the SuC shall be configured to protect data within the SuC requiring safeguarding, from unauthorized disclosure or modification, whether at rest or in transit. The security requirements should be documented in the TRA reports, including Security Controls and dataflows.

Section 4.2 provides the Data Protection Countermeasures, including the protection of Data Storage Points/Document and Dataflows Identification.

## 2.5 Data Flow Diagram (DFD)

The dataflow Diagram of the SuC could refer to Figure 2-3 ILRA updated Network Diagram of the SuC. After ILRA analysis and partition the zones and conduits, the preliminary required equipments of security countermeasures also be presented in the diagram. For detail could refer to “Network_diagram_20241113-Data Flow Diagram.pdf”

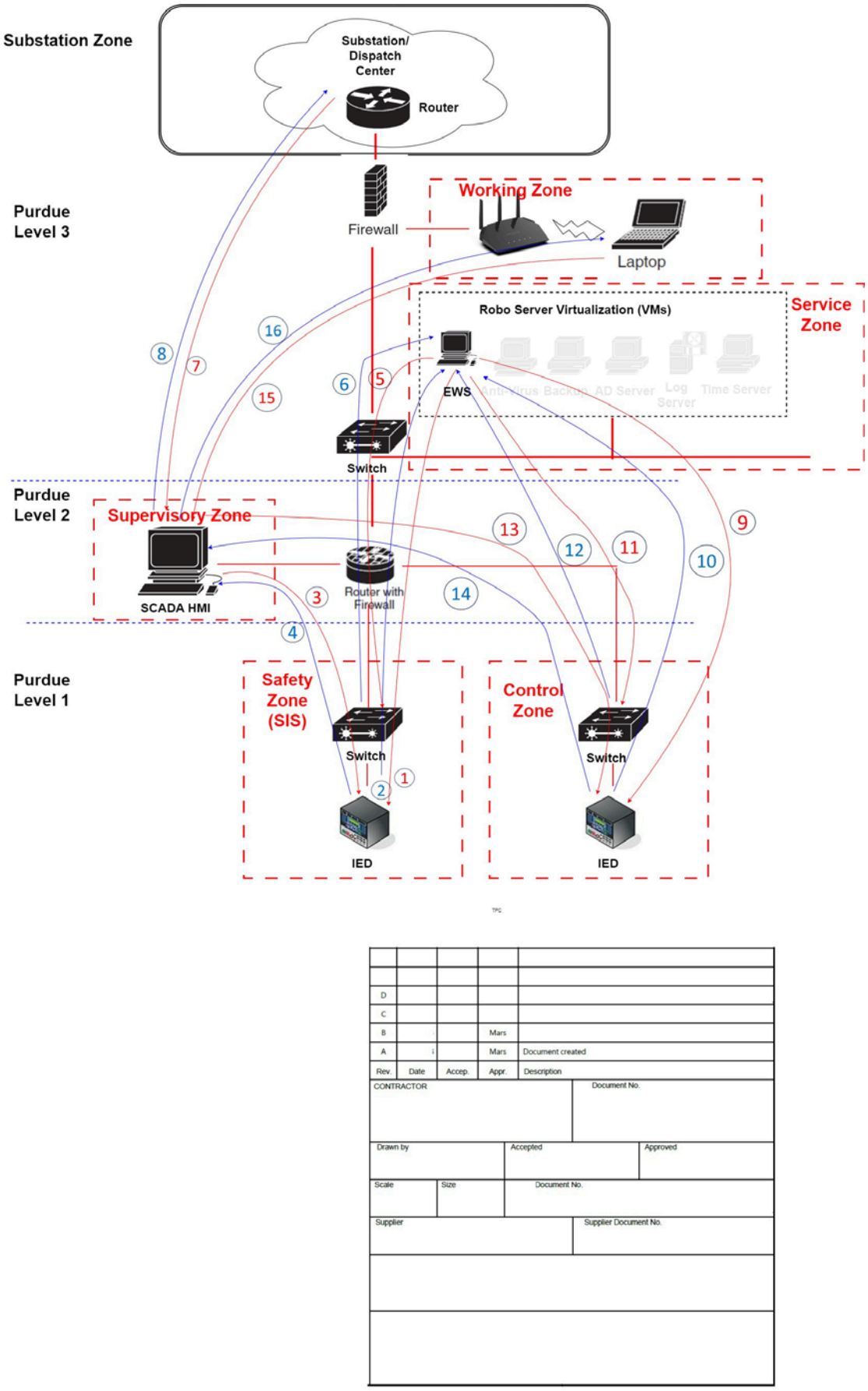
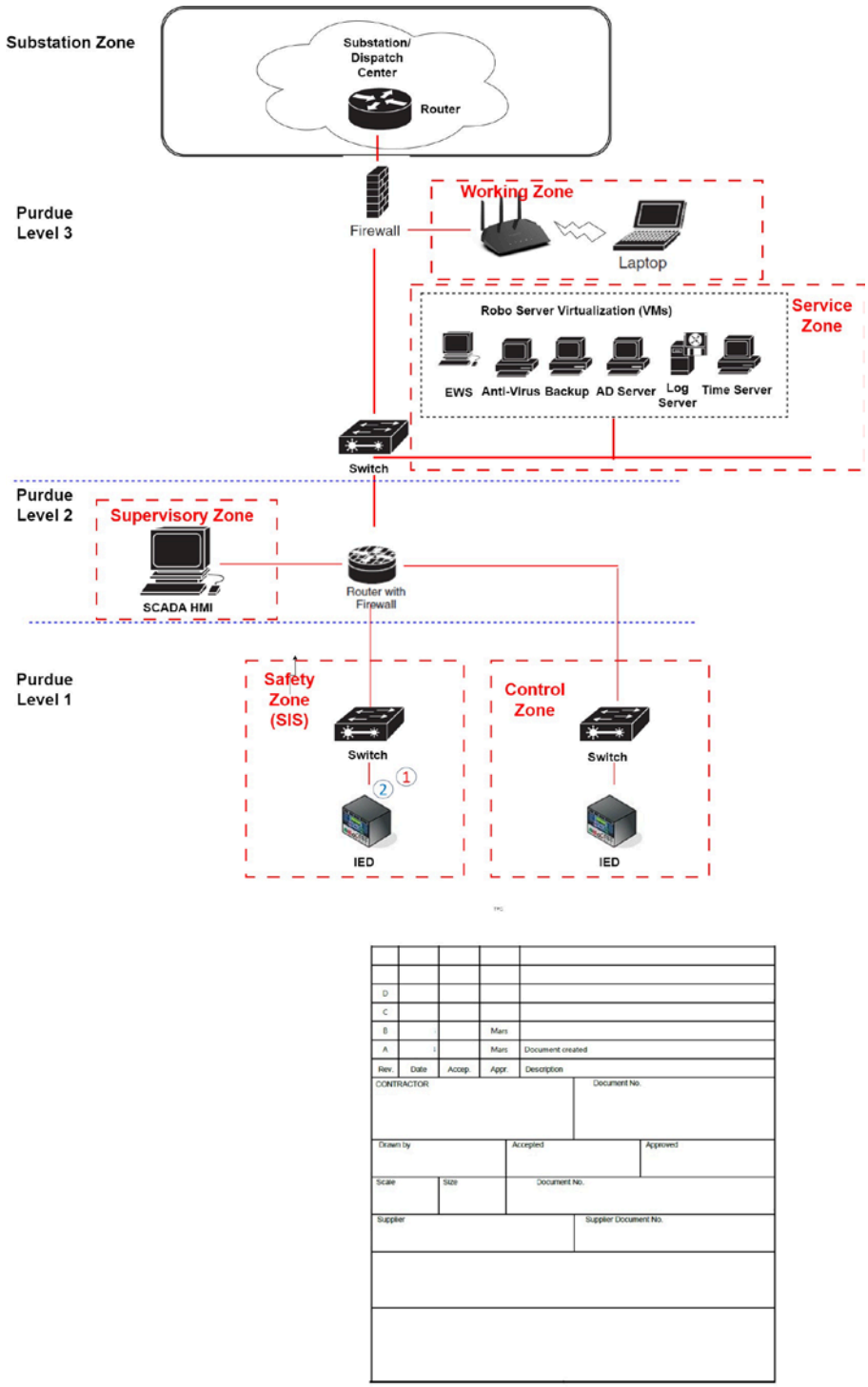



Figure 2-3 Data Flow Diagram of the SuC.

(Refer to “Dummy Project - Data Flow Diagram.doc” chap 4.0)




## 2.6 Possible Threats

### 2.6.1 Description of the Threat Source

| Threat-Vulnerability ID | Asset | Threats Description | Vulnerability Description |
|---|---|---|---|

| | | | |
|---|---|---|---|
| TV-01-001 | SCADA HMI Server | TR-4 : Data Access : "(CT08) Internal Disgruntled Employee" attack the "Data_Storage_Configuration File" | SW.V021 : Lack of back-up copies |
| TV-01-002 | SCADA HMI Server | TR-4 : Data Access : "(CT08) Internal Disgruntled Employee" attack the "Data_Storage_Configuration File" | SW.V021 : Lack of back-up copies |
| TV-01-003 | SCADA HMI Server | GTS9 : Interception of communications : "(CT04) Targeted Attack (Skilled)" attack the "Network_Communication_Command & Control Packet" | NET.V010 : Unprotected network connections |
| TV-01-004 | SCADA HMI Server | GTS4 : Intrusion via Remote Access : "(CT08) Internal Disgruntled Employee" attack the "Software_IACS SW_Operational Functionality" | PS.V004 : Incorrect use of software and hardware |
| TV-01-005 | SCADA HMI Server | GTS5 : ICS insider : "(CT08) Internal Disgruntled Employee" attack the "Software_IACS SW_Operational Functionality" | PS.V004 : Incorrect use of software and hardware |
| TV-01-006 | SCADA HMI Server | TR-8 : Application compromise : "(CT10) Internal Criminal (Sabotage)" attack the "Software_IACS SW_Command & Control Action" | SW.V020 : Uncontrolled downloading and use of software |
| TV-01-007 | SCADA HMI Server | TR-3 : Account takeover : "(CT10) Internal Criminal (Sabotage)" attack the "Software_IACS SW_Command & Control Action" | SW.V015 : Poor password management |
| TV-01-008 | SCADA HMI Server | GTS4 : Intrusion via Remote Access : "(CT08) Internal Disgruntled Employee" attack the "Operation System_Windows_Service" | NET.V006 : Lack of identification and authentication mechanisms like user identification |
| TV-01-009 | SCADA HMI Server | TR-6 : Vulnerability exploits : "(CT10) Internal Criminal (Sabotage)" attack the "Operation System_Windows_Service" | PS.V006 : Lack of monitoring mechanisms |
| TV-01-010 | SCADA HMI Server | TR-9 : Open ports : "(CT09) Internal General Hacktivist" attack the "Operation System_Windows_Service" | SW.V016 : Unnecessary services enabled |
| TV-01-011 | SCADA HMI Server | GTS2 : Infection via Internet and Intranet : "(CT02) General Malware/ Unintentional/ Non-targeted" attack the "Operation System_Windows_Service" | SW.V021 : Lack of back-up copies |
| TV-01-012 | SCADA HMI Server | GTS1 : Malware - Infection via Removable Media and External Hardware : "(CT14) External 3rd Party (e.g., Competitor)" attack the "Hardware_Peripheral _Peripheral Interface Using (USB, ...)" | HW.V010 : Uncontrolled copying |
| TV-01-013 | SCADA HMI Server | TR-3 : Account takeover : "(CT10) Internal Criminal (Sabotage)" attack the "User_IAM_Account Name & Password" | SW.V015 : Poor password management |

| | | | |
|---|---|---|---|
| TV-01-014 | IED (Control) | TR-4 : Data Access : "(CT08) Internal Disgruntled Employee" attack the "Data_Storage_Configuration File" | SW.V021 : Lack of back-up copies |
| TV-01-015 | IED (Control) | TR-3 : Account takeover : "(CT10) Internal Criminal (Sabotage)" attack the "Software_IACS SW_Command & Control Action" | SW.V015 : Poor password management |
| TV-01-016 | IED (Control) | TR-6 : Vulnerability exploits : "(CT10) Internal Criminal (Sabotage)" attack the "Operation System_Embedded_Firmware" | SW.V021 : Lack of back-up copies |
| TV-01-017 | IED (Control) | GTS1 : Malware - Infection via Removable Media and External Hardware : "(CT09) Internal General Hacktivist" attack the "Hardware_Peripheral _Peripheral Interface Using (USB, ...)" | HW.V009 : Lack of debug port protection |
| TV-01-018 | IED (Protect) | TR-4 : Data Access : "(CT08) Internal Disgruntled Employee" attack the "Data_Storage_Configuration File" | SW.V021 : Lack of back-up copies |
| TV-01-019 | IED (Protect) | TR-3 : Account takeover : "(CT10) Internal Criminal (Sabotage)" attack the "Software_IACS SW_Command & Control Action" | SW.V015 : Poor password management |
| TV-01-020 | IED (Protect) | TR-6 : Vulnerability exploits : "(CT10) Internal Criminal (Sabotage)" attack the "Operation System_Embedded_Firmware" | SW.V021 : Lack of back-up copies |
| TV-01-021 | IED (Protect) | GTS1 : Malware - Infection via Removable Media and External Hardware : "(CT09) Internal General Hacktivist" attack the "Hardware_Peripheral _Peripheral Interface Using (USB, ...)" | HW.V009 : Lack of debug port protection |
| TV-01-022 | Ethernet Switch (Control) | TR-4 : Data Access : "(CT08) Internal Disgruntled Employee" attack the "Data_Storage_Configuration File" | SW.V021 : Lack of back-up copies |
| TV-01-023 | Ethernet Switch (Control) | TR-3 : Account takeover : "(CT10) Internal Criminal (Sabotage)" attack the "Software_Web Service_Data-Storage" | NET.V006 : Lack of identification and authentication mechanisms like user identification |
| TV-01-024 | Ethernet Switch (Control) | TR-6 : Vulnerability exploits : "(CT10) Internal Criminal (Sabotage)" attack the "Operation System_Embedded_Firmware" | SW.V021 : Lack of back-up copies |
| TV-01-025 | Ethernet Switch (Protection) | TR-4 : Data Access : "(CT08) Internal Disgruntled Employee" attack the "Data_Storage_Configuration File" | SW.V021 : Lack of back-up copies |
| TV-01-026 | Ethernet Switch (Protection) | TR-3 : Account takeover : "(CT10) Internal Criminal (Sabotage)" attack the "Software_Web Service_Data-Storage" | NET.V006 : Lack of identification and authentication mechanisms like user identification |

| | | | |
|---|---|---|---|
| TV-01-027 | Ethernet Switch (Protection) | TR-6 : Vulnerability exploits : "(CT10) Internal Criminal (Sabotage)" attack the "Operation System_Embedded_Firmware" | SW.V021 : Lack of back-up copies |

(Refer to “Dummy Project - ILRA-DTRA.xlsx” DTRA)

### 2.6.2 Possible Threat Events

| Threat-Vulnerability ID | Asset | Events |
|---|---|---|
| TV-01-001 | SCADA HMI Server | T.IAC+T.SI : Corruption of data |
| TV-01-002 | SCADA HMI Server | T.IAC+T.SI : Corruption of data |
| TV-01-003 | SCADA HMI Server | T.IAC+T.UC : Tampering with communication |
| TV-01-004 | SCADA HMI Server | T.IAC+T.UC : Abuse of rights |
| TV-01-005 | SCADA HMI Server | T.IAC+T.UC : Abuse of rights |
| TV-01-006 | SCADA HMI Server | T.IAC+T.SI : Tampering with software |
| TV-01-007 | SCADA HMI Server | T.IAC+T.UC : Abuse of rights |
| TV-01-008 | SCADA HMI Server | T.IAC+T.UC : Abuse of rights |
| TV-01-009 | SCADA HMI Server | T.IAC : Forging of rights |
| TV-01-010 | SCADA HMI Server | T.IAC+T.DC : Remote spying |
| TV-01-011 | SCADA HMI Server | T.IAC+T.DC : Destroy/ Loss/Theft of equipment |
| TV-01-012 | SCADA HMI Server | T.IAC+T.UC : Use of counterfeit or copied software |
| TV-01-013 | SCADA HMI Server | T.IAC+T.UC : Unauthorised use of equipment |
| TV-01-014 | IED (Control) | T.IAC+T.SI : Corruption of data |
| TV-01-015 | IED (Control) | T.IAC+T.UC : Abuse of rights |
| TV-01-016 | IED (Control) | T.IAC+T.DC : Destroy/ Loss/Theft of equipment |
| TV-01-017 | IED (Control) | T.IAC+T.UC : Use of counterfeit or copied software |
| TV-01-018 | IED (Protect) | T.IAC+T.SI : Corruption of data |
| TV-01-019 | IED (Protect) | T.IAC+T.UC : Abuse of rights |
| TV-01-020 | IED (Protect) | T.IAC+T.DC : Destroy/ Loss/Theft of equipment |
| TV-01-021 | IED (Protect) | T.IAC+T.UC : Use of counterfeit or copied software |
| TV-01-022 | Ethernet Switch (Control) | T.IAC+T.SI : Corruption of data |
| TV-01-023 | Ethernet Switch (Control) | T.IAC+T.UC : Illegal processing of data |
| TV-01-024 | Ethernet Switch (Control) | T.IAC+T.DC : Destroy/ Loss/Theft of equipment |
| TV-01-025 | Ethernet Switch (Protection) | T.IAC+T.SI : Corruption of data |
| TV-01-026 | Ethernet Switch (Protection) | T.IAC+T.UC : Illegal processing of data |
| TV-01-027 | Ethernet Switch (Protection) | T.IAC+T.DC : Destroy/ Loss/Theft of equipment |
| TV-01-028 | Ethernet Switch (Protection) | T.IAC+T.UC+T.TRE Denial of event logging |

(Refer to “Dummy Project - ILRA-DTRA.xlsx” DTRA)

## 2.7 Potential Impact to the Environment

### 2.7.1 The possible sequence of attacks and impacts

| Threat-Vulnerability ID | Asset | Attack Methods and Scenarios Description | Unwanted Incidents | Consequences |
|---|---|---|---|---|
| TV-01-001 | SCADA HMI Server | "(CT08) Internal Disgruntled Employee" may make a threat to "Data_Storage_Configuration File", by using "TR-4 : Data Access" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.SI : Corruption of data" event. | C-004 : The monitoring system is blind. | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-002 | SCADA HMI Server | "(CT08) Internal Disgruntled Employee" may make a threat to "Data_Storage_Configuration File", by using "TR-4 : Data Access" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.SI : Corruption of data" event. | C-003 : Loss of control of the control system | Triggers internal investigations and review<br>Loss of remote control of substation. |
| TV-01-003 | SCADA HMI Server | "(CT04) Targeted Attack (Skilled)" may make a threat to "Network_Communication_Command & Control Packet", by using "GTS9 : Interception of communications" to exploit "NET.V010 : Unprotected network connections" vulnerability to cause "T.IAC+T.UC : Tampering with communication" event. | C-003 : Loss of control of the control system | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-004 | SCADA HMI Server | "(CT08) Internal Disgruntled Employee" may make a threat to "Software_IACS SW_Operational Functionality", by using "GTS4 : Intrusion via Remote Access" to exploit "PS.V004 : Incorrect use of software and hardware" vulnerability to cause "T.IAC+T.UC : Abuse of rights" event. | C-003 : Loss of control of the control system | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-005 | SCADA HMI Server | "(CT08) Internal Disgruntled Employee" may make a threat to "Software_IACS SW_Operational Functionality", by using "GTS5 : ICS insider" to exploit "PS.V004 : Incorrect use of software and hardware" vulnerability to cause "T.IAC+T.UC : Abuse of rights" event. | C-003 : Loss of control of the control system | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-006 | SCADA HMI Server | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Software_IACS SW_Command & Control Action", by | C-003 : Loss of control of | Outage of power service < 24 hour<br>Triggers internal |

| | | | | |
|---|---|---|---|---|
| | | using "TR-8 : Application compromise" to exploit "SW.V020 : Uncontrolled downloading and use of software" vulnerability to cause "T.IAC+T.SI : Tampering with software" event. | the control system | investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-007 | SCADA HMI Server | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Software_IACS SW_Command & Control Action", by using "TR-3 : Account takeover" to exploit "SW.V015 : Poor password management" vulnerability to cause "T.IAC+T.UC : Abuse of rights" event. | C-003 : Loss of control of the control system | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-008 | SCADA HMI Server | "(CT08) Internal Disgruntled Employee" may make a threat to "Operation System_Windows_Service", by using "GTS4 : Intrusion via Remote Access" to exploit "NET.V006 : Lack of identification and authentication mechanisms like user identification" vulnerability to cause "T.IAC+T.UC : Abuse of rights" event. | C-003 : Loss of control of the control system | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-009 | SCADA HMI Server | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Operation System_Windows_Service", by using "TR-6 : Vulnerability exploits" to exploit "PS.V006 : Lack of monitoring mechanisms" vulnerability to cause "T.IAC : Forging of rights" event. | C-005 : Monitor data leakage | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-010 | SCADA HMI Server | "(CT09) Internal General Hacktivist" may make a threat to "Operation System_Windows_Service", by using "TR-9 : Open ports" to exploit "SW.V016 : Unnecessary services enabled" vulnerability to cause "T.IAC+T.DC : Remote spying" event. | C-005 : Monitor data leakage | Triggers internal investigations and review<br>Local media exposure |
| TV-01-011 | SCADA HMI Server | "(CT02) General Malware/ Unintentional/ Non-targeted" may make a threat to "Operation System_Windows_Service", by using "GTS2 : Infection via Internet and Intranet" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.DC : Destroy/ Loss/Theft of equipment" event. | C-010 : Internet service failure | Triggers internal investigations and review<br>Local media exposure |
| TV-01-012 | SCADA HMI Server | "(CT14) External 3rd Party (e.g., Competitor)" may make a threat to "Hardware_Peripheral _Peripheral | C-005 : Monitor data leakage | Triggers internal investigations and review<br>Local media exposure |

| | | | | |
|---|---|---|---|---|
| | | Interface Using (USB, ...)", by using "GTS1 : Malware - Infection via Removable Media and External Hardware" to exploit "HW.V010 : Uncontrolled copying" vulnerability to cause "T.IAC+T.UC : Use of counterfeit or copied software" event. | | Loss of remote control of substation. |
| TV-01-013 | SCADA HMI Server | "(CT10) Internal Criminal (Sabotage)" may make a threat to "User_IAM_Account Name & Password", by using "TR-3 : Account takeover" to exploit "SW.V015 : Poor password management" vulnerability to cause "T.IAC+T.UC : Unauthorised use of equipment" event. | C-003 : Loss of control of the control system | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-014 | IED (Control) | "(CT08) Internal Disgruntled Employee" may make a threat to "Data_Storage_Configuration File", by using "TR-4 : Data Access" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.SI : Corruption of data" event. | C-003 : Loss of control of the control system | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-015 | IED (Control) | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Software_IACS SW_Command & Control Action", by using "TR-3 : Account takeover" to exploit "SW.V015 : Poor password management" vulnerability to cause "T.IAC+T.UC : Abuse of rights" event. | C-001 : Unexpected control system commands | Triggers internal investigations and reviewLocal media exposureLoss of remote control of substation. |
| TV-01-016 | IED (Control) | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Operation System_Embedded_Firmware", by using "TR-6 : Vulnerability exploits" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.DC : Destroy/ Loss/Theft of equipment" event. | C-007 : Control system failure/down | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-017 | IED (Control) | "(CT09) Internal General Hacktivist" may make a threat to "Hardware_Peripheral _Peripheral Interface Using (USB, ...)", by using "GTS1 : Malware - Infection via Removable Media and External Hardware" to exploit "HW.V009 : Lack of debug port protection" vulnerability to cause "T.IAC+T.UC : Use of counterfeit or copied software" event. | C-007 : Control system failure/down | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-018 | IED (Protect) | "(CT08) Internal Disgruntled Employee" may make a threat to | C-003 : Loss of | Injury of personal<br>Outage of power service > |

| | | | | |
|---|---|---|---|---|
| | | "Data_Storage_Configuration File", by using "TR-4 : Data Access" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.SI : Corruption of data" event. | control of the control system | 24 hours<br>Breaches of ordinaces (noise, shadow flickering, visual impact, wild life)<br>National media exposure<br>Loss of operating capability of system |
| TV-01-019 | IED (Protect) | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Software_IACS SW_Command & Control Action", by using "TR-3 : Account takeover" to exploit "SW.V015 : Poor password management" vulnerability to cause "T.IAC+T.UC : Abuse of rights" event. | C-001 : Unexpected control system commands | Injury of personal<br>Outage of power service > 24 hours<br>Breaches of ordinaces (noise, shadow flickering, visual impact, wild life)<br>National media exposure<br>Loss of operating capability of system |
| TV-01-020 | IED (Protect) | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Operation System_Embedded_Firmware", by using "TR-6 : Vulnerability exploits" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.DC : Destroy/ Loss/Theft of equipment" event. | C-007 : Control system failure/down | Injury of personal<br>Outage of power service > 24 hours<br>Breaches of ordinaces (noise, shadow flickering, visual impact, wild life)<br>National media exposure<br>Loss of operating capability of system |
| TV-01-021 | IED (Protect) | "(CT09) Internal General Hacktivist" may make a threat to "Hardware_Peripheral _Peripheral Interface Using (USB, ...)", by using "GTS1 : Malware - Infection via Removable Media and External Hardware" to exploit "HW.V009 : Lack of debug port protection" vulnerability to cause "T.IAC+T.UC : Use of counterfeit or copied software" event. | C-007 : Control system failure/down | Injury of personal<br>Outage of power service > 24 hours<br>Breaches of ordinaces (noise, shadow flickering, visual impact, wild life)<br>National media exposure<br>Loss of operating capability of system |
| TV-01-022 | Ethernet Switch (Control) | "(CT08) Internal Disgruntled Employee" may make a threat to "Data_Storage_Configuration File", by using "TR-4 : Data Access" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.SI : Corruption of data" event.<br>(Lost of network service) | C-010 : Internet service failure | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-023 | Ethernet Switch (Control) | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Software_Web Service_Data-Storage", by using "TR-3 : Account takeover" to exploit "NET.V006 : Lack of identification and authentication mechanisms like user identification" vulnerability to | C-010 : Internet service failure | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |

| | | | | |
|---|---|---|---|---|
| | | cause "T.IAC+T.UC : Illegal processing of data" event.<br>(Lost of network service) | | |
| TV-01-024 | Ethernet Switch (Control) | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Operation System_Embedded_Firmware", by using "TR-6 : Vulnerability exploits" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.DC : Destroy/ Loss/Theft of equipment" event.<br>(Lost of network service) | C-010 : Internet service failure | Outage of power service < 24 hour<br>Triggers internal investigations and review<br>Local media exposure<br>Loss of remote control of substation. |
| TV-01-025 | Ethernet Switch (Protection) | "(CT08) Internal Disgruntled Employee" may make a threat to "Data_Storage_Configuration File", by using "TR-4 : Data Access" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.SI : Corruption of data" event.<br>(Lost of network service) | C-010 : Internet service failure | Injury of personal<br>Outage of power service > 24 hours<br>Breaches of ordinaces (noise, shadow flickering, visual impact, wild life)<br>National media exposure<br>Loss of operating capability of system |
| TV-01-026 | Ethernet Switch (Protection) | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Software_Web Service_Data-Storage", by using "TR-3 : Account takeover" to exploit "NET.V006 : Lack of identification and authentication mechanisms like user identification" vulnerability to cause "T.IAC+T.UC : Illegal processing of data" event.<br>(Lost of network service) | C-010 : Internet service failure | Injury of personal<br>Outage of power service > 24 hours<br>Breaches of ordinaces (noise, shadow flickering, visual impact, wild life)<br>National media exposure<br>Loss of operating capability of system |
| TV-01-027 | Ethernet Switch (Protection) | "(CT10) Internal Criminal (Sabotage)" may make a threat to "Operation System_Embedded_Firmware", by using "TR-6 : Vulnerability exploits" to exploit "SW.V021 : Lack of back-up copies" vulnerability to cause "T.IAC+T.DC : Destroy/ Loss/Theft of equipment" event.<br>(Lost of network service) | C-010 : Internet service failure | Injury of personal<br>Outage of power service > 24 hours<br>Breaches of ordinaces (noise, shadow flickering, visual impact, wild life)<br>National media exposure<br>Loss of operating capability of system |

(Refer to “Dummy Project - ILRA-DTRA.xlsx” DTRA)

### 2.7.2 Unmitigated risks, security measures, and residual risks

All “Risk Tolerable or Acceptable?” are “Y”

(Refer to “Dummy Project - ILRA-DTRA.xlsx” DTRA)

# 3.0 Security Profile

## 3.1 The Proforma Form for Conducting the High-Level Cybersecurity Risk Assessment (HLCRA) results

(Refer to “Dummy Project - ILRA-DTRA.xlsx” ILRA)

## 3.2 The Proforma Form for Conducting the Detailed Risk Assessment Requirements (DRAR)

(Refer to “Dummy Project - ILRA-DTRA.xlsx” ILRA)

## 3.3 Analysis Tools and Results

The security risk assessment results and the proposed security measures and/or countermeasures for a threat modelling were documented in “Dummy Project - ILRA-DTRA.xlsx” spreadsheet ILRA and DTRA.

# 4.0 Requirements for Security Controls

## 4.1 Cybersecurity Function Requirements Specification (Equipment/ Device Security)

| Asset | Cybersecurity Function Requirements |
|---|---|
| SCADA HMI Server | SR 1.01 - Human user identification and authentication<br>SR 1.02 -Software process and device identification and authentication<br>SR 1.03 - Account management<br>SR 1.04 - Identifier management<br>SR 1.05 - Authenticator management<br>SR 1.07 - Strength of password-based authentication<br>SR 1.11 - Unsuccessful login attempts<br>SR 2.01 - Authorization enforcement<br>SR 2.05 - Session lock<br>SR 2.06 – Remote Session termination<br>SR 2.08 - Auditable EVENTs<br>SR 3.1 - Communication integrity<br>SR 3.4 - Software and information integrity<br>SR 4.1 - Information confidentiality<br>SR 4.3 - Use of cryptography<br>SR 6.1 - Audit log accessibility<br>SR 7.3 – Control System backup |
| IED (Control) | TBD |
| IED (Protect) | TBD |
| Ethernet Switch (Control) | TBD |
| Ethernet Switch (Protection) | TBD |

## 4.2 Data Protection Countermeasures

| Asset | Data Protection Requirements |
|---|---|
| SCADA HMI Server | C22 : Management of Change (MOC) - Well-defined management of Change procedure, independent review, administrative Control, passive Countermeasure<br>C37 : Backup and restore the System/Software/Data - Build a backup and restore for the System/Software/Data<br>C15 : Encrypted Communiacations - Assuming robust encryption algorithm (e.g., AES) |
| IED (Control) | TBD |
| IED (Protect) | TBD |
| Ethernet Switch (Control) | TBD |
| Ethernet Switch (Protection) | TBD |
| Data storage points (requirement from ID01 7.3.1 4.(4) | data to be protected and protect requirements include (this list is not exhaustive):<br>- legal or regulatory information, (TBD) |

| | |
|---|---|
| | – PE/O confidential data, including proprietary data (e.g. recipes) and data identified in NDAs or other contractual vehicles, (TBD)<br>– configuration and operational data (e.g. commands and parameters), (TBD)<br>– system data, such as cryptographic materials (e.g. keys and certificates), access control lists, passwords, network device data, (TBD)<br>– audit and event logs, (TBD)<br>– backup data, (TBD)<br>– historical data, (TBD)<br>– data warehouses.(TBD) |

## 4.3 Hardware Protection Countermeasures

| Asset | Hardware Protection Requirements |
|---|---|
| SCADA HMI Server | C6 : Block/disable unused ports - Well-defined hardening process, device owner, periodic review of implemented hardening, active countermeasure<br>C19 : Locked Enclosure - Well-defined physical security practices with security personnel and periodic inspection, active countermeasure |
| IED (Control) | TBD |
| IED (Protect) | TBD |
| Ethernet Switch (Control) | TBD |
| Ethernet Switch (Protection) | TBD |

## 4.4 System Administration Countermeasures

| Asset | System Administration Requirements |
|---|---|
| SCADA HMI Server | C2 : Access control list of who has access to engineering source file - Well-defined account management process, consistent guidelines for strong passwords, passive countermeasure<br>C3 : Anti-virus software or End-point Protection - Well-defined hardening process, device owner, periodic anti-virus table updates, automatic scanning, active countermeasure<br>C6 : Block/disable unused ports - Well-defined hardening process, device owner, periodic review of implemented hardening, active countermeasure<br>C20 : Log review/analysis - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and |

| | |
|---|---|
| | responsibilities, clearly defined log review frequency, passive countermeasure<br>C23 : Multi-Factor Authentication (MFA) - Well-defined account management process, consistent guidelines for strong passwords, active countermeasure<br>C26 : Periodic review of the Application Program - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure<br>C29 : Remove Unneccessary Services - Well-defined hardening process, device owner, periodic review of implemented hardening, active countermeasure<br>C30 : Remove Unneccessary Software - Well-defined hardening process, device owner, periodic review of implemented hardening, active countermeasure<br>C32 : Review of User Accounts and Permissions (former employees, e.g. retired, terminated) - Well-defined account management process, consistent guidelines for strong passwords, passive countermeasure<br>C34 : SIEM- Security incident and event monitoring - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, tuning and configuration of SIEM, ensure alarm management principles are considered, passive countermeasure management<br>C34 : SIEM- Security incident and event monitoring - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, tuning and configuration of SIEM, ensure alarm management principles are considered, passive countermeasure management<br>C35 : Strong Unique Passwords - Well-defined account process, consistent guidelines for strong passwords, passive countermeasure<br>C37 : Backup and restore the System/Software/Data - Build a backup and restore for the System/Software/Data |
| IED (Control) | TBD |
| IED (Protect) | TBD |
| Ethernet Switch (Control) | TBD |
| Ethernet Switch (Protection) | TBD |

## 4.5 Application Security Countermeasures

| Asset | Cybersecurity Function Requirements |
|---|---|
| SCADA HMI Server | C2 : Access control list of who has access to engineering source file - Well-defined account management process, consistent guidelines for strong passwords, passive countermeasure<br>C32 : Review of User Accounts and Permissions (former employees, e.g. retired, terminated) - Well-defined account management process, consistent guidelines for strong passwords, passive countermeasure<br>C35 : Strong Unique Passwords - Well-defined account process, consistent guidelines for strong passwords, passive countermeasure |
| IED (Control) | TBD |
| IED (Protect) | TBD |
| Ethernet Switch (Control) | TBD |
| Ethernet Switch (Protection) | TBD |

### 4.6 Network Security Countermeasures

| Asset | Cybersecurity Function Requirements |
|---|---|
| SCADA HMI Server | C24 : NIDS- Network intrusion detection system - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure<br>Firewall & Rule Policy<br>Zone & Conduit Segmentation |
| IED (Control) | TBD |
| IED (Protect) | TBD |
| Ethernet Switch (Control) | TBD |
| Ethernet Switch (Protection) | TBD |

### 4.7 Advanced Mitigation Strategies

| Asset | Cybersecurity Function Requirements |
|---|---|
| SCADA HMI Server | C1 : 24 Hour Operator staffing - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure<br>C12 : Door Locks - Well-defined physical security practices with security personnel and periodic inspection, active countermeasure<br>C17 : Firewall logs that monitor access - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure |

| | |
|---|---|
| | C20 : Log review/analysis - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, clearly defined log review frequency, passive countermeasure<br>C21 : Managed Switch with Access Control List (ACL) - Well-defined firewall ACL, device owner, periodic review of ACL, active countermeasure<br>C22 : Management of Change (MOC) - Well-defined management of change procedure, independent review, administrative control, passive countermeasure<br>C24 : NIDS- Network intrusion detection system - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure<br>C33 : Separation of duty (limiting the number of critical systems that can be impacted from a single account) - Well-defined account management process, consistent guidelines for strong passwords, active countermeasure |
| IED (Control) | TBD |
| IED (Protect) | TBD |
| Ethernet Switch (Control) | TBD |
| Ethernet Switch (Protection) | TBD |

### 4.8 Policies & Procedures Integration Requirements

| Asset | Cybersecurity Function Requirements |
|---|---|
| SCADA HMI Server | SM-1 : User Account & Access Control Management - Microsoft Windows AD<br>SM-2 : Assets Management Sever (AMS) - OPSWAT Neuralyzer<br>SM-3 : Backup/ Restore Mechanism - A Local Backup Server and/or NAS<br>SM-4 : Backup/ Restore Mechanism - Acronis Agent & integrated to Data Center<br>SM-5 : Anti-Malware Protection Mechanism - Palo Alto Antivirus SW and A DMZ Patch Management Server<br>SM-6 : Security monitoring and log collection - SPLUNK local agent and integrated to CDC CENTER SIEM<br>SM-6 : Security monitoring and log collection - SPLUNK local agent and integrated to CDC CENTER SIEM<br>SM-7 : Patch Management - A DMZ Patch Management Server<br>SM-8 : Network Intrusion Dection (IDS) Mechanism - OPSWAT Neuralyzer<br>SM-9 : Portable Disk Vulnerability & Malware Management - OPSWAT MetaDefender Kiosk™ |

| | |
|---|---|
| | SM-10 : Security Policy & Procedure Documents (Function/Operation Documents)<br>SM-11 : System Security Hardening<br>SM-12 : Account Management Hardening<br>SM-13 : Remote Access (Remote desktop protocol, RDP) security<br>SM-14 : Configuration management<br>SM-15 : Wireless management |
| IED (Control) | TBD |
| IED (Protect) | TBD |
| Ethernet Switch (Control) | TBD |
| Ethernet Switch (Protection) | TBD |

### 4.9 Security Level Requirements

| | |
|---|---|
| SCADA HMI for Supervisory | 2 |
| IED (Control) | 1 |
| IED (Protect) | 2 |
| Ethernet Switch (Control) | 1 |
| Ethernet Switch (Protection) | 2 |

## 5.0 The requirements of defense-in-depth architecture of SuC

The first default rule in all Firewall of OT Conduit should be “Deny All”.

The defense-in-depth architecture of SuC include:

1. Outside zone to Purdue Level 3
   (1) Setup a Firewall with limiting the allowed asset and service connetion from Substation Zone to Supervisory zone and Service zone.
   (2) Require multi-factor authentication for the connetion from Substayion Zone.
   (3) Encrypt the connetion from Substayion Zone.
   (4) Setup a firewall with limiting the allowed asset and service connetion from Working Zone to Supervisory zone.
   (5) Request the security for Web access from Working Zone to Supervisory zone.
   (6) Encrypt the connetion from Working Zone.
2. Purdue Level 3 to Purdue Level 2
   (1) Setup a Managed Switch with whitelisting asset list to limit the allowed asset and service connetion from Service Zone to Supervisory zone, Safety Zone, and Control zone.
3. Purdue Level 2 to Purdue Level 1
   (1) Setup a Router with Firewall with whitelisting asset list to limit the allowed asset and service connetion from Service Zone, Supervisory zone to Safety Zone, and Control zone. The whitelisting allowed data flow should be limited to 4.0 SuC dataflow diagram.

(2) Setup a Router with Firewall with firewall rule only allow limiting asset and service connetion from Supervisory zone to Safety Zone. The whitelisting allowed data flow should be limited to 4.0 SuC dataflow diagram.

(3) All the communications external to the Safety (SIS) Zone, including remote access communications, should be prohibited to interfere with the operation of the SIS. All remote access communications (ex. Port 3389) with IPs in Safety (SIS) Zone should be denied in Router with Firewall rules.

(4) The IEDs in Safety (SIS) Zone should set to “Run mode” in configuration application or by a manual physical switch (disable SIS configuration mode) when they are under operation, to prohibit the SIS from being configured.

<<Text End>>